# Task1: Vulnerability Assessment Report

**Website Tested:** TestPHP VulnWeb
**Scope:** Public pages only, passive, read-only
**Tools Used:** Nmap, Browser DevTools, OWASP ZAP (passive), securityheaders.com
**Date:** 28 February 2026
**Prepared by:** Zamzam Hassan Ali

## 1. Executive Summary

This assessment evaluates the publicly accessible security configuration of TestPHP VulnWeb. The analysis was **passive and read-only**, following ethical guidelines.

The goal is to identify **common security weaknesses**, classify risks in a business-friendly way, and provide practical recommendations for remediation.

Key findings include missing security headers, server information disclosure, and minor configuration issues.

## 2. Methodology / Tools Used

| Section | Details |
|---|---|
| Website Tested | http://testphp.vulnweb.com |
| Scope | Public pages only, read-only, passive scanning |
| Tools Used | Nmap, Browser DevTools, OWASP ZAP (passive), securityheaders.com |
| Notes | No login attempts, no exploitation, no active scanning |

**Methodology:**

1. Nmap used to identify open ports (Port 80).
2. Browser DevTools checked HTTP headers, cookies, server information.
3. securityheaders.com tested for missing or insecure headers.

4. OWASP ZAP performed passive scan to detect configuration and header issues on public pages.

## 3. Findings

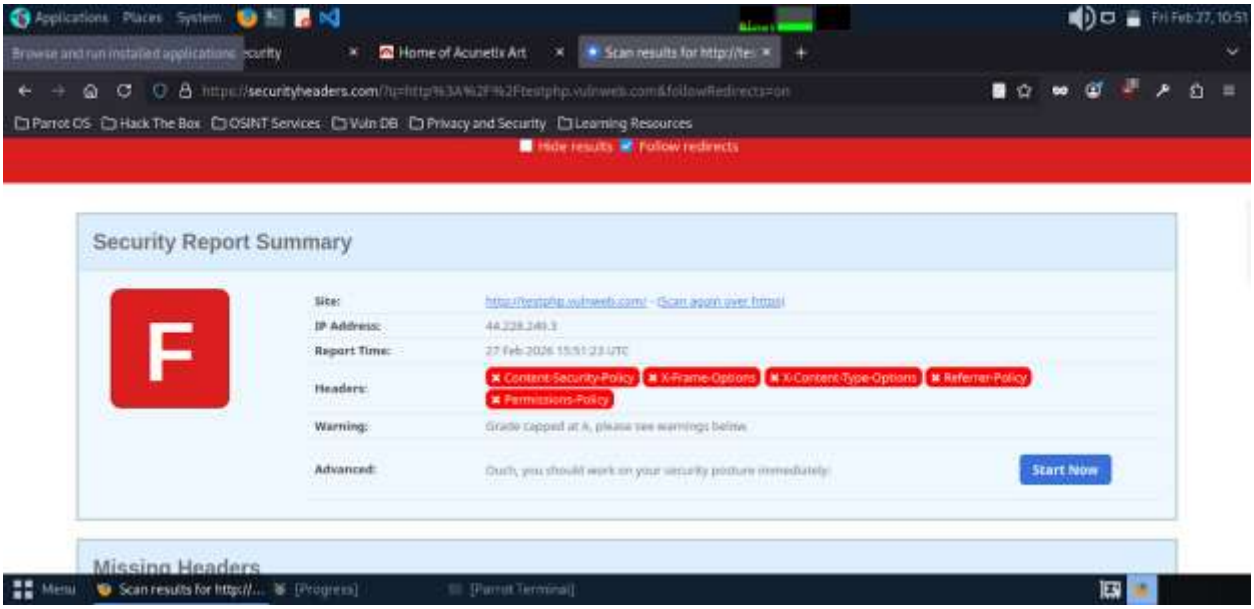
| # | Finding | Risk | Explanation (Non-technical) | Recommendation |
|---|---|---|---|---|
| 1 | Missing Content-Security-Policy | Medium | Browser cannot block some malicious scripts from untrusted sites | Add CSP header in web server configuration |
| 2 | Missing Anti-Clickjacking (X-Frame-Options) | Medium | Website could be embedded in another site to trick users | Add X-Frame-Options header (DENY or SAMEORIGIN) |
| 3 | X-Content-Type-Options missing | Low | Browser may misinterpret file types, causing security issues | Add X-Content-Type-Options: nosniff |
| 4 | Server reveals backend via X-Powered-By | Low | Exposes server technology to attackers | Remove X-Powered-By header from server |
| 5 | Charset mismatch | Informational | Character encoding is not clearly specified | Specify UTF-8 charset in headers |
| 6 | HTTP only (no HTTPS) | High | Data is transmitted unencrypted and can be intercepted | Implement HTTPS & HSTS |

**Note:** This report only includes passive, read-only findings. No login attempts, brute force, or exploitation were performed.

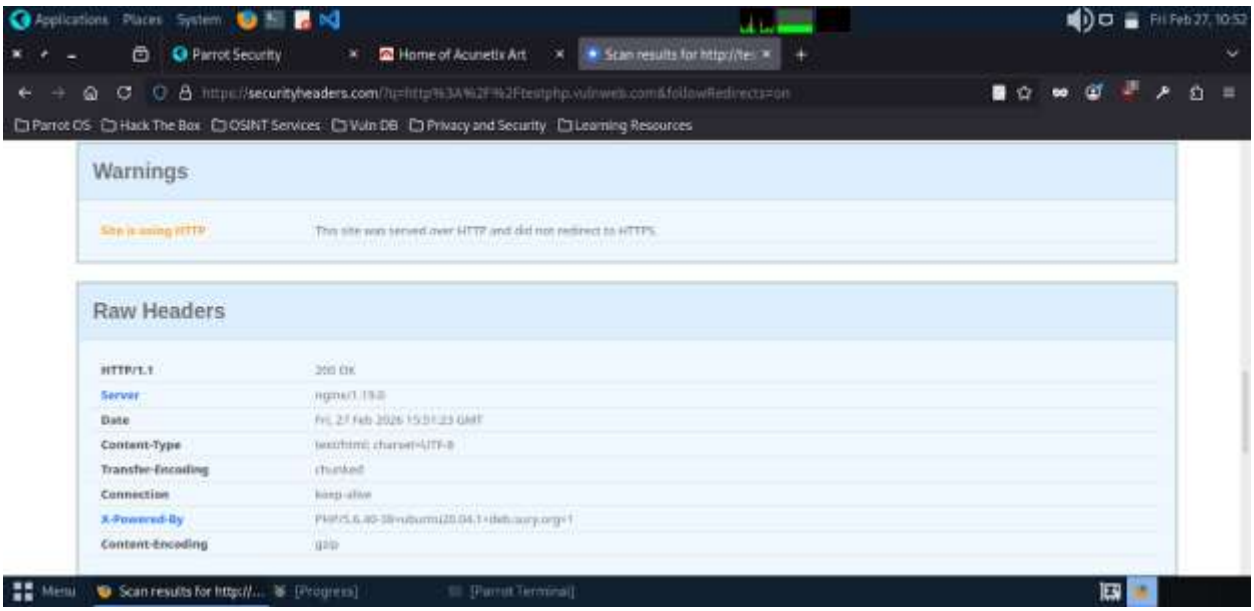
## 4. Evidence

**Include the following screenshots:**

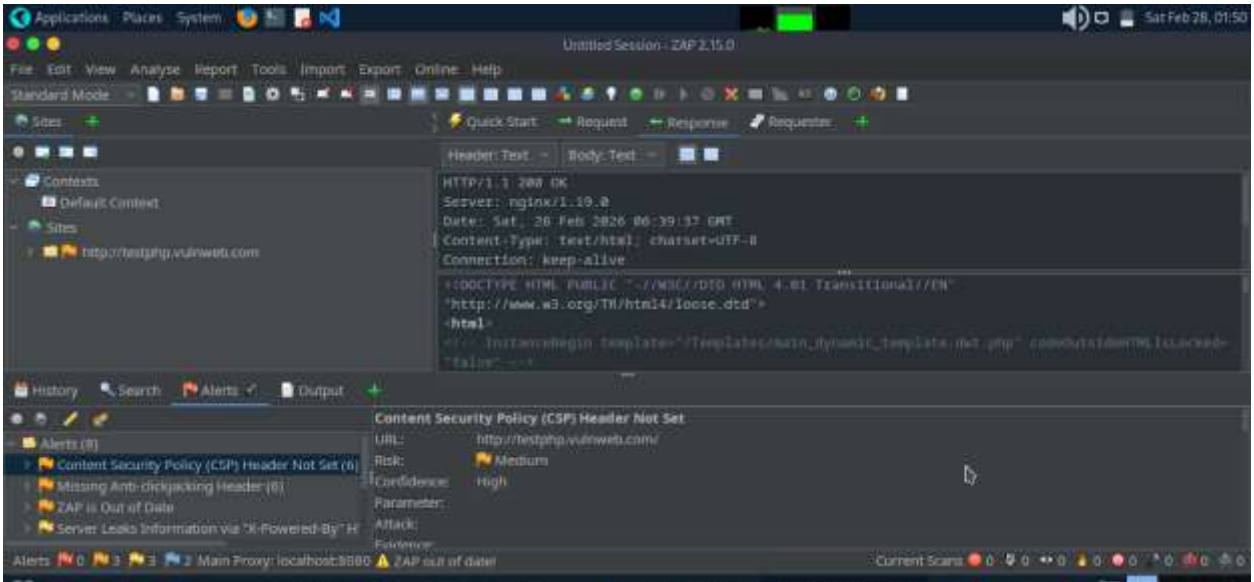
1. Browser DevTools → Missing security headers (CSP, X-Frame-Options, X-Content-Type-Options)
2. securityheaders.com screenshot → F grade

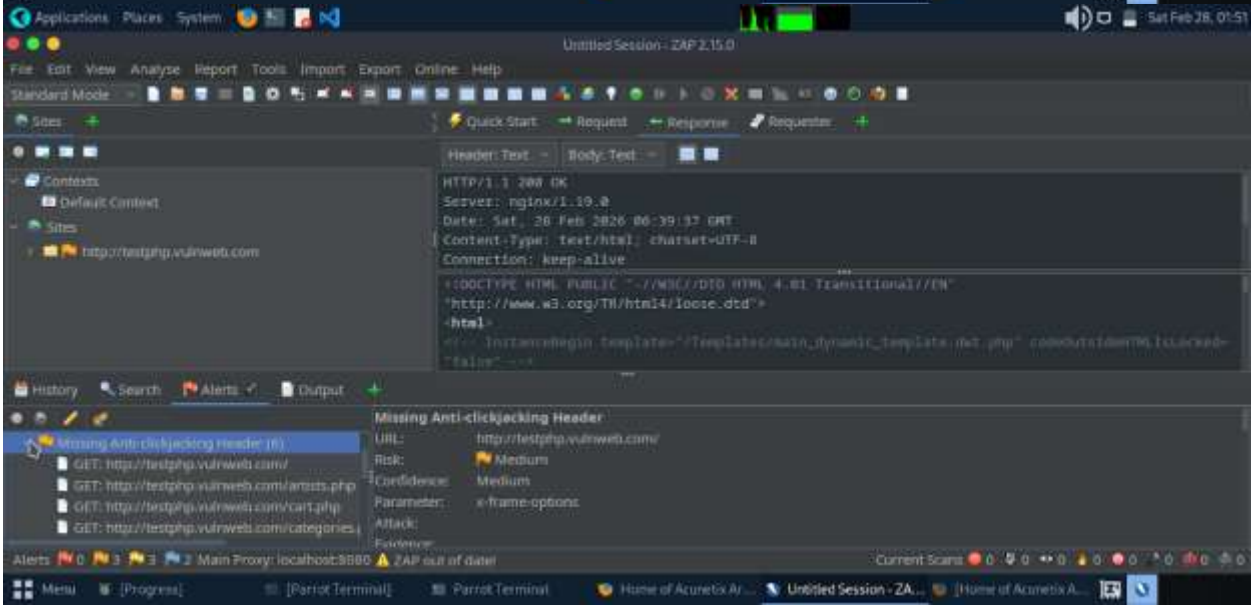


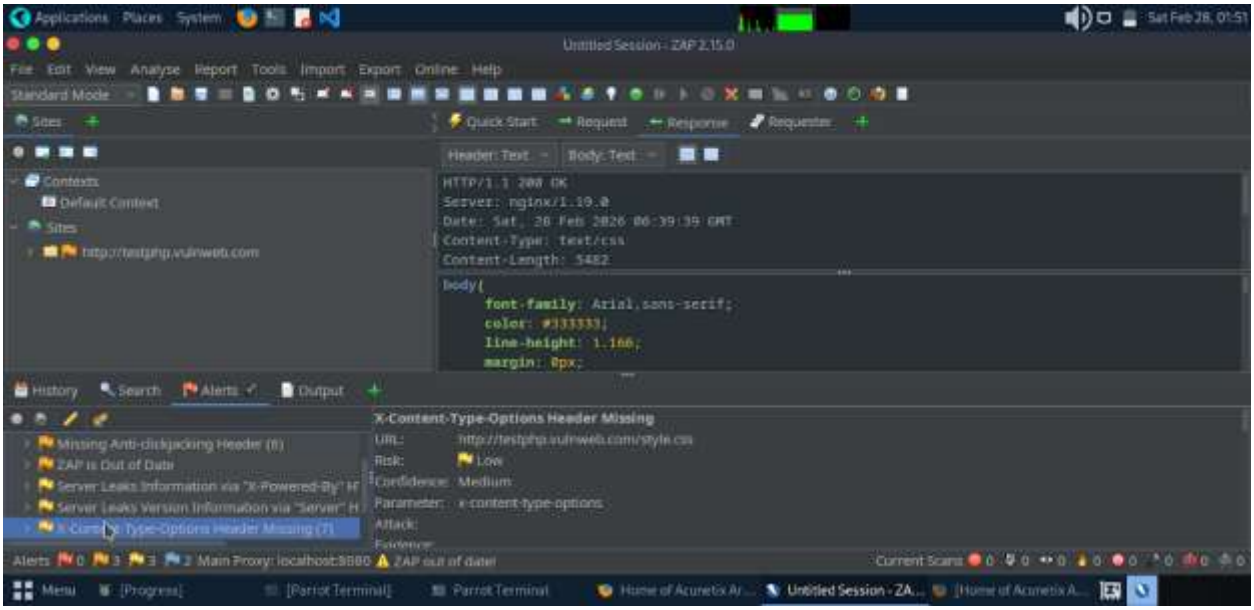

3. Server information (X-Powered-By / Server header)



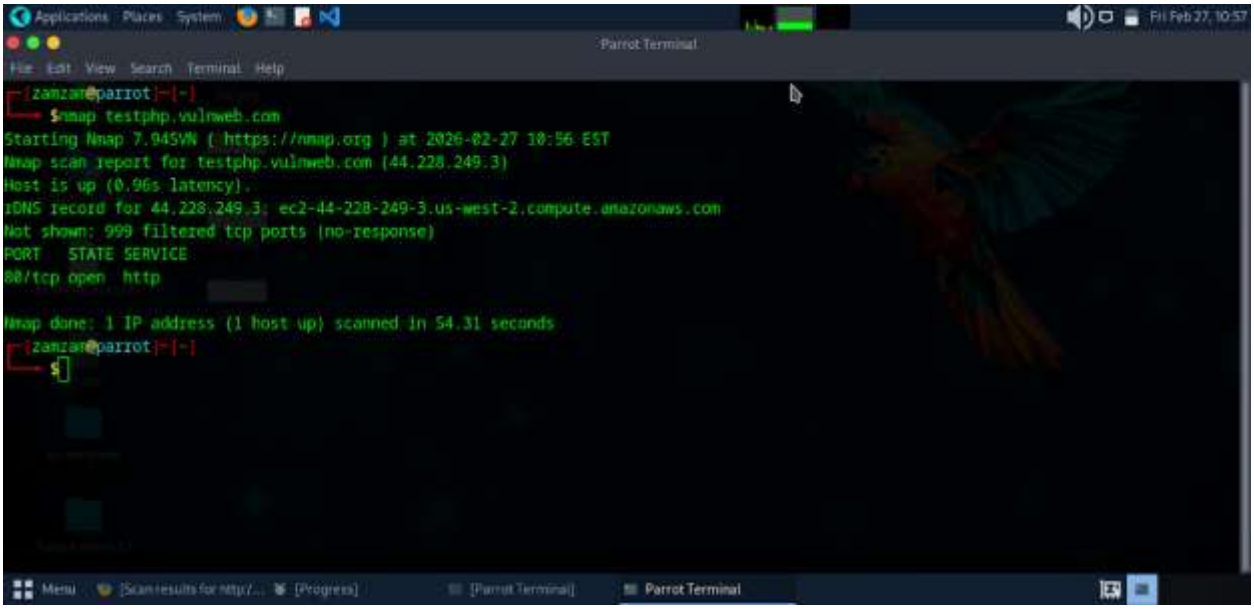

4. ZAP Alerts → passive scan


Applications Places System
Sat Feb 28, 01:50
Untitled Session - ZAP 2.15.0
File Edit View Analyse Report Tools Import Export Online Help
Standard Mode
Sites
Quick Start
Request
Response
Requester
Header: Text
Body: Text
Contexts
Default Context
Sites
http://testphp.vulnweb.com
HTTP/1.1 200 OK
Server: nginx/1.19.0
Date: Sat, 28 Feb 2026 06:39:37 GMT
Content-Type: text/html; charset=UTF-8
Connection: keep-alive
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN"
"http://www.w3.org/TR/html4/loose.dtd">
<html>
History
Search
Alerts
Output
Alerts (8)
Content Security Policy (CSP) Header Not Set (6)
Missing Anti-clickjacking Header (6)
ZAP is Out of Date
Server Leaks Information via "X-Powered-By" H
Content Security Policy (CSP) Header Not Set
URL: http://testphp.vulnweb.com/
Risk: Medium
Confidence: High
Parameter:
Attack:
Evidence:
Alerts 0 3 3 2 Main Proxy: localhost:8080 ZAP out of date!
Current Scans 0 0 0 0 0 0 0 0 0 0 0
Menu
[Progress]
[Parrot Terminal]
Parrot Terminal
Home of Acunetix Ar...
Untitled Session - ZA...
[Home of Acunetix A...

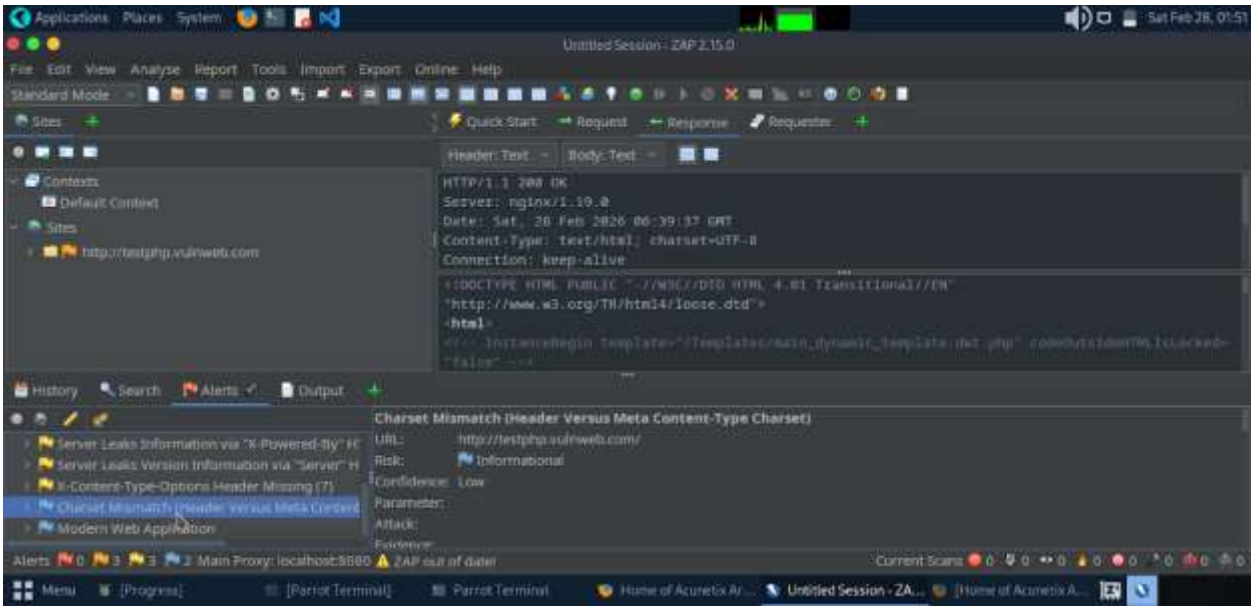

Applications Places System
Sat Feb 28, 01:51
Untitled Session - ZAP 2.15.0
File Edit View Analyse Report Tools Import Export Online Help
Standard Mode
Sites
Quick Start
Request
Response
Requester
Header: Text
Body: Text
Contexts
Default Context
Sites
http://testphp.vulnweb.com
HTTP/1.1 200 OK
Server: nginx/1.19.0
Date: Sat, 28 Feb 2026 06:39:37 GMT
Content-Type: text/html; charset=UTF-8
Connection: keep-alive
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN"
"http://www.w3.org/TR/html4/loose.dtd">
<html>
History
Search
Alerts
Output
Missing Anti-clickjacking Header (6)
GET: http://testphp.vulnweb.com/
GET: http://testphp.vulnweb.com/artists.php
GET: http://testphp.vulnweb.com/cart.php
GET: http://testphp.vulnweb.com/categories.
Missing Anti-clickjacking Header
URL: http://testphp.vulnweb.com/
Risk: Medium
Confidence: Medium
Parameter: x-frame-options
Attack:
Evidence:
Alerts 0 3 3 2 Main Proxy: localhost:8080 ZAP out of date!
Current Scans 0 0 0 0 0 0 0 0 0 0 0
Menu
[Progress]
[Parrot Terminal]
Parrot Terminal
Home of Acunetix Ar...
Untitled Session - ZA...
[Home of Acunetix A...




5. Nmap scan → Port 80 open




6. Charset mismatch evidence




## 5. Recommendations

1. Implement HTTPS & enforce HSTS.
2. Add missing security headers: Content-Security-Policy, X-Frame-Options, X-Content-Type-Options.
3. Hide server information and backend technology (remove X-Powered-By header).
4. Specify proper charset (UTF-8) for all pages.
5. Continue passive monitoring for future changes.